

Layered Authorization: Enterprise Floor, Mission Edge

Oct 6, 2026 · @Adam

Summary

This proposal extends enterprise ICAM governance to mission-specific access decisions. Enterprise ICAM remains the sole source of identity and the authoritative decision on every request. A new mission layer refines access inside boundaries that ICAM approves, and it can only narrow access, never widen it. ICAM gains approval authority over those boundaries, control of the rule that combines the two decisions, a kill switch for every mission, and complete visibility into every decision made under the pattern.

The one-line version: **the STS proves who you are, enterprise ICAM decides what you are cleared for, and the mission decides what that means here, within limits ICAM sets.**

Why now

Enterprise ICAM has already done the hard foundational work: authentication is centralized and authorization decisions are externalized from applications. What has changed is demand. Mission-specific rules, such as position-based access, workflow state, and data release conditions, are multiplying faster than any enterprise-wide entitlement catalog can reasonably absorb. That is a structural limit of serving every mission's fine-grained needs from one central catalog, not a shortcoming of the team that runs it. At the same time, our developer platform relies on a bespoke auth proxy that combines token handling and access logic in one unstandardized component.

The question is not whether mission-level rules will exist; they already do, scattered across applications and workarounds. The question is whether they exist under enterprise ICAM governance or outside it.

Alignment with enterprise mandates

This pattern implements the target architecture enterprise ICAM is already measured against:

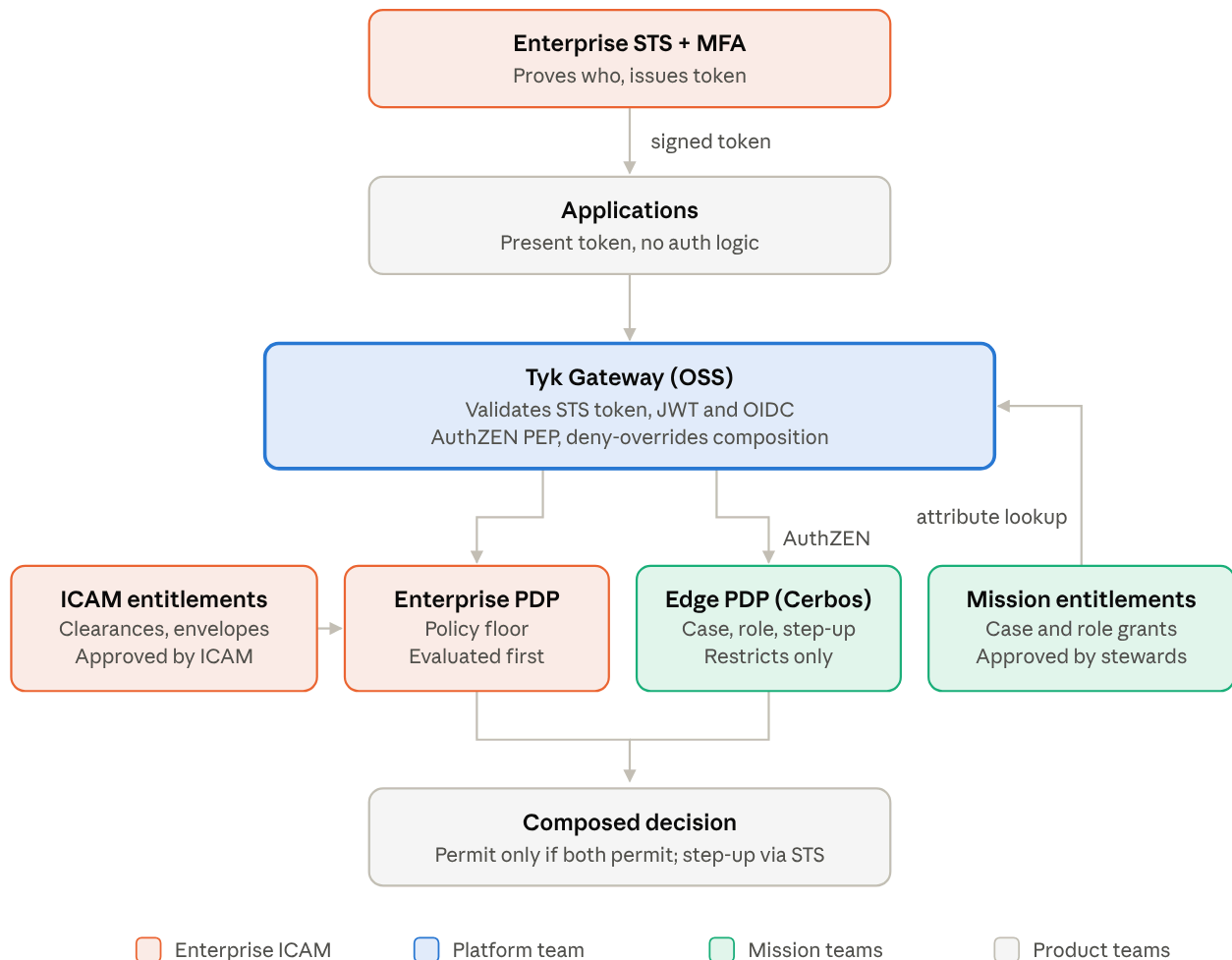
- **NIST SP 800-207, Zero Trust Architecture:** per-request decisions by policy decision points, enforced by policy enforcement points.
- **NIST SP 800-162, Attribute Based Access Control:** access derived from governed subject, resource, and environment attributes.
- **NIST SP 800-53 controls:** including AC-3 (access enforcement), AC-16 (security and privacy attributes), and AC-24 (access control decisions). A full mapping appears later in this document.
- **OpenID AuthZEN Authorization API 1.0:** an approved OpenID Foundation Final Specification for the interface between enforcement and decision points, chosen so that no mission or application depends on a single vendor.

Design principles

1. **Enterprise ICAM is the floor, and the floor is authoritative.** Decisions compose with deny-overrides: the mission layer may add restrictions but can never grant what the enterprise denies.
2. **Enterprise ICAM governs the pattern.** ICAM approves access envelopes, the composition rule, mission adoption, and the promotion of attributes to the enterprise catalog.
3. **Ownership follows rate of change.** Identity, clearances, and attributes of record change slowly and remain with ICAM. Mission rules change frequently and are maintained by the teams closest to them, under ICAM-approved boundaries.
4. **The mission layer never authenticates.** The enterprise STS and MFA remain the only source of identity and the only place stronger proof is collected.
5. **One standard contract.** Applications request decisions through AuthZEN and never depend on which engine answered.
6. **The gateway holds no business rules.** It validates, asks, composes, and logs. Policy lives only in the decision points, where it is reviewed and tested.

Architecture

Identity proves who, the enterprise sets the floor, the mission refines



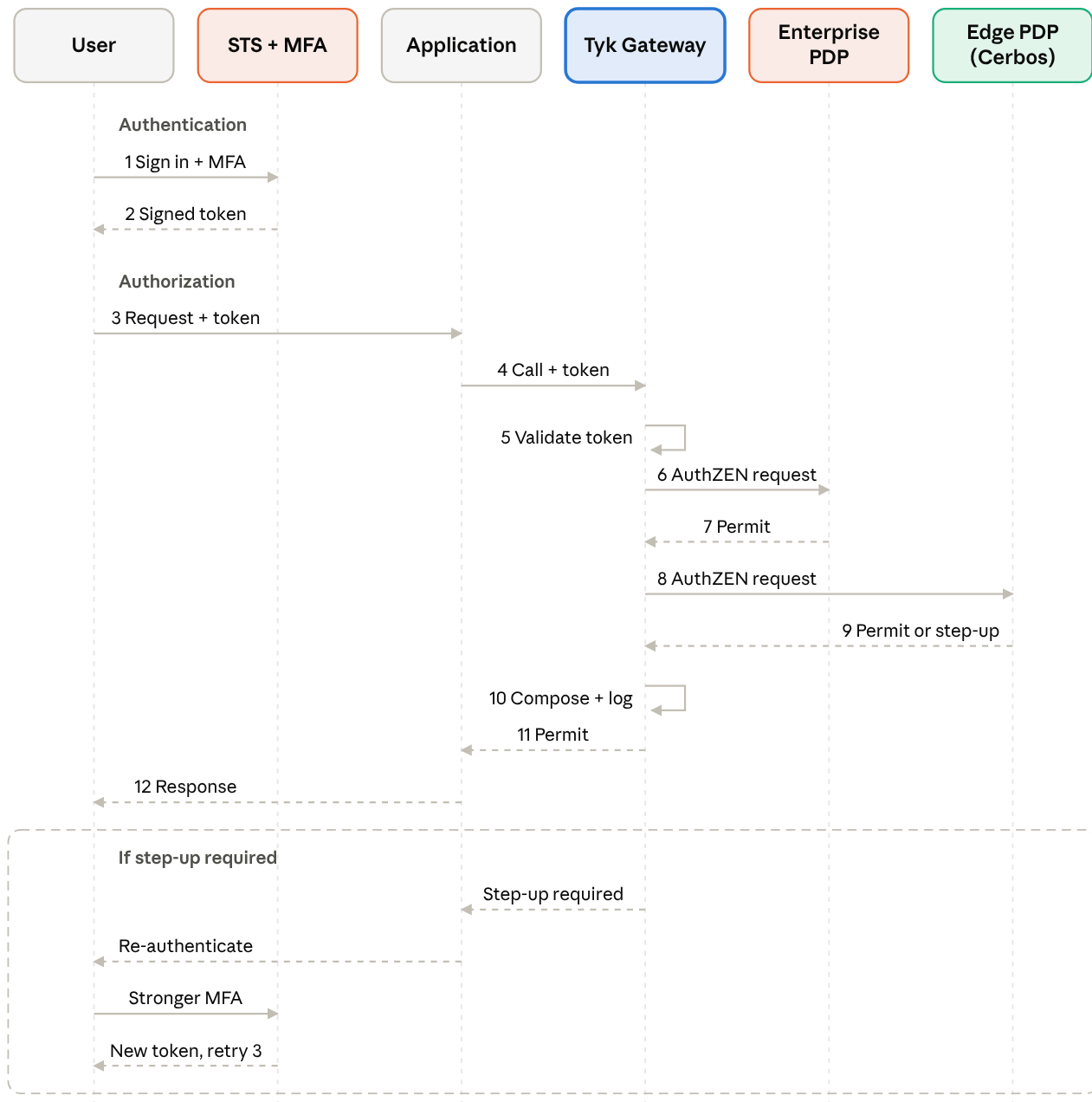
layered authorization · identity, gateway, two PDPs, one composed decision

Every request passes through one enterprise identity check and two decision points, with the enterprise decision evaluated first. Each decision point draws on its own entitlement source: ICAM entitlements feed the enterprise decision point directly, while mission entitlements such as case and role assignments reach the mission decision point through gateway attribute lookup. Colors show who owns each component; the step-up path is shown in the sequence diagram below.

Request flow

1. The user authenticates through the enterprise IdP with MFA. The STS issues a short-lived signed token carrying identity, key claims, and authentication strength (assurance level and methods).
2. The application forwards the request with its token to Tyk Gateway.
3. Tyk validates the token against the enterprise STS signing keys, audience, and expiry. This replaces the token-handling role of today's auth proxy.
4. Tyk builds a standard AuthZEN subject, action, resource, and context request from the token claims and request metadata.
5. The enterprise decision point evaluates first. A deny ends the request immediately.
6. On an enterprise permit, the same request goes to the Cerbos mission decision point, which applies mission, position, workflow, and assurance rules.
7. Tyk composes the result: permit only if both permit. Both verdicts are logged under one correlation ID and are available to enterprise ICAM.

One authentication, two authorization checks, one composed decision



sequence · authentication, two authorization checks, step-up branch

Solid arrows are requests and dashed arrows are responses. An enterprise deny at step 7 ends the request immediately and Tyk returns a denial without calling the mission decision point. A step-up result at step 9 sends the user back through the enterprise STS for stronger authentication, and the retried request re-enters at step 3.

Authentication and step-up

Authentication strength becomes a policy input, which strengthens enterprise authentication rather than bypassing it. Routine actions may rely on the session's original MFA, while sensitive actions such as release or export can require fresh, phishing-resistant authentication. When a mission policy requires higher assurance, the decision returns a step-up reason, the application sends the user back through the enterprise STS, and the retried request succeeds. Policy decides when stronger proof is needed; the enterprise IdP remains the only component that collects it.

For service-to-service calls, services use STS token exchange (RFC 8693) to obtain downstream-scoped tokens that preserve both the user and the calling service. Both decision points can then constrain which services may act on behalf of which users, closing the confused-deputy gap common to proxy designs.

Authorization surfaces

Authorization is not always one HTTP request. Every surface ultimately answers the same question, **can user X operate on object Y**, but the mechanism must fit the shape of the work. A search that returns 10,000 objects must not trigger 10,000 dual decisions, and it must not return 10,000 objects and filter them afterward.

The governing principle is **decide per subject, filter per object**. Subject-side constraints are computed once per user or session, then pushed down into the data store as a filter, so the store returns only what the user may see. Individual object decisions are reserved for small, bounded sets.

Surface	Question	Mechanism	Enterprise contribution	Mission contribution
Single action	Can Jane print this file?	One composed decision at the gateway	Decision on the request	Decision on the request
Interface rendering	Which actions can Jane take on the items on this page?	One batch evaluation for a bounded set, routed through the gateway	Batch decision or a cached subject-level answer	Batch decision

Surface	Question	Mechanism	Enterprise contribution	Mission contribution
Search and listing	Which of these objects may Jane see?	Query planning converted to a data store filter before the query runs	One subject-level answer: may Jane search this mission's data, and up to which marking	A filter condition from the Cerbos query plan, such as case IDs on Jane's assignments
Exports and long-running jobs	May this job act on these objects for Jane?	Job runs on Jane's behalf through token exchange, applies the same filter, and re-checks before delivery	Subject-level answer at job start and before delivery	Filter at selection; decision at delivery
Events and subscriptions	May Jane receive this stream of updates?	Decision at subscription time; each message filtered by its attributes; subscriptions re-evaluated when attributes change	Subscription decision	Subscription decision and message filter
AI retrieval and agents	May this agent retrieve or act on this content for Jane?	Retrieval uses the same pushed-down filter before content reaches the model; tool calls are decided like any other action	Same as search and actions	Same as search and actions

Surface	Question	Mechanism	Enterprise contribution	Mission contribution
Derived and cached data	Who may see a summary, index, or copy built from protected objects?	Derived artifacts inherit the most restrictive attributes of their sources and are filtered like the originals	Marking vocabulary for inherited labels	Mission tags carried forward

How search works without 10,000 decisions

1. When Jane searches, the gateway asks the enterprise one subject-level question: may Jane search this mission's data, and up to which marking? That is one decision, cached briefly for the session.
2. The gateway asks Cerbos for a query plan rather than a decision. Cerbos returns a condition, such as case ID in Jane's assigned cases and not in any screened cases.
3. The two are combined into a single filter and translated into the data store's native query, such as an Elasticsearch boolean filter on marking, mission tag, and case ID.
4. The data store returns only permitted objects. Counts, facets, and aggregations are computed after filtering, so they cannot reveal the existence of objects Jane may not see.
5. If a residual rule cannot be expressed as a filter, it is evaluated only on the page of results actually displayed, through one batch call.

Requirements this places on the design

- **Objects must carry their authorization attributes.** Every indexed object includes the marking, mission tag, case ID, and any other attribute a filter needs. An attribute that is not indexed cannot be filtered on.
- **Filters come from policy, not from application code.** Filters are generated from the same Cerbos policies that make individual decisions, never re-implemented by hand in each application.
- **Filters and decisions must agree.** Automated tests sample objects and verify that the generated filter and the individual decision give the same answer, so the two paths cannot drift apart.

- **Every surface is behind an enforcement point.** Direct data access, analytics tools, and bulk exports either go through the gateway or apply filters generated from the same policies. Any surface without one is a path around the design.
- **Enterprise answers are expressed at the subject level for collections.** If the enterprise decision service cannot produce query plans, its contribution to collection surfaces is a subject-level ceiling, such as the highest marking Jane may access within this mission, which the gateway converts into a filter.

What enterprise ICAM gains

- **Authority extended, not shared.** The enterprise decision is evaluated first on every request and cannot be overridden. ICAM's reach extends into mission decisions it does not have to author.
- **New approval rights.** ICAM approves access envelopes, the composition rule, which missions adopt the pattern, and which attributes graduate to the enterprise catalog.
- **A kill switch.** ICAM can revert any mission to enterprise-only decisions at any time, which is today's baseline.
- **More visibility than today.** Every decision records both the enterprise and mission verdicts with a correlation ID, giving ICAM telemetry on mission-level access it currently cannot see.
- **Lower request volume.** Fine-grained distinctions inside an approved envelope no longer arrive as individual entitlement requests, freeing ICAM to focus on enterprise-level decisions.
- **Rogue authorization brought into the light.** Mission rules that today live in application code and workarounds move into one governed, auditable pattern.

Ownership

Component	Owner	Responsibility
Enterprise STS and MFA	Enterprise ICAM	Authenticate users, issue tokens, perform step-up
Enterprise decision point	Enterprise ICAM	Clearances, attributes of record, enterprise policy floor

Component	Owner	Responsibility
Composition rule and kill switch	Enterprise ICAM approves; platform team operates	Deny-overrides; the mission layer can only narrow
Tyk Gateway	Platform team	Token validation, AuthZEN enforcement, composition, decision logging
Cerbos and mission policies	Mission data steward policy shop, implemented by mission engineering, approved through engineering governance	Mission, position, workflow, and step-up rules
Applications	Product teams	Present tokens, honor decisions, carry no embedded authorization logic

The envelope model

Narrow-only composition means the mission layer cannot grant access the enterprise has not. New access is therefore always an ICAM decision, expressed as an access envelope: a stable, coarse entitlement such as permission to release within one mission's data. ICAM approves the envelope through its existing process. Inside that envelope, the mission manages fine-grained distinctions as needs change. ICAM sets every boundary; missions refine within them; and the volume of narrow, per-use-case requests reaching ICAM falls.

The pattern distinguishes two kinds of change, which differ in frequency and in who decides them:

Kind of change	Example	Frequency	Decided by
Vocabulary change	Adding a new release marking or a new value to an enterprise attribute	Rare	Enterprise ICAM
Access change within an envelope	Allowing analysts assigned to a specific case to release its products	Frequent	Mission policy, through mission governance

Enterprise ICAM retains every vocabulary change with enterprise meaning and every new envelope. The frequent, mission-specific access changes are expressed as mission policy over mission attributes, so they no longer require individual entitlement actions by ICAM.

Attribute governance

Every attribute has exactly one authoritative source. Ownership of the overall catalog is shared, divided by attribute type, with enterprise ICAM owning every attribute of record. The rows below are illustrative and will be confirmed against actual systems of record with ICAM during co-design.

Attribute	Category	Owner	System of record	Reaches the decision points via	Freshness	Usable by
User identity	Subject, of record	Enterprise ICAM	Enterprise IdP	Token claim	Per session	Both decision points
Clearance and accesses	Subject, of record	Enterprise ICAM and security	Personnel security system	Enterprise PIP lookup	Authoritative at decision time	Enterprise decision point; mission read-only
Position assignment	Subject, of record	HR and personnel	Personnel system	Token claim or PIP	On change	Both decision points
Authentication strength	Environment	Enterprise ICAM	Enterprise STS	Token claim	Per token	Both decision points; mission for step-up
Access envelopes	Entitlement	Enterprise ICAM	Entitlement management system	Enterprise PIP lookup	On approval or revocation	Enterprise decision point
Classification markings	Resource	Vocabulary: enterprise security. Application: mission data steward policy shop	Originating system or data catalog	Resource metadata in request	On creation or change	Both decision points

Attribute	Category	Owner	System of record	Reaches the decision points via	Freshness	Usable by
Mission data tag	Resource	Mission data steward policy shop	Data catalog	Resource metadata in request	On change	Mission decision point
Mission role and cell membership	Subject, mission-derived	Mission data steward policy shop	Mission roster	Gateway enrichment	On change	Mission decision point, restrictive rules only
Workflow or case state	Resource, mission-derived	Owning application	Application data store	Resource metadata in request	Per request	Mission decision point, restrictive rules only
Network zone and device posture	Environment	Platform team	Gateway and endpoint management	Gateway context	Per request	Both decision points

Governing rules:

1. **One owner per attribute.** If two parties can write the same attribute, it is not authoritative.
2. **The mission layer never writes or caches enterprise attributes.** It reads them from the token or the enterprise PIP at decision time.
3. **Mission-derived attributes only restrict.** They may narrow access inside an envelope but never stand in for a clearance or entitlement.
4. **Register before use.** A policy may reference only attributes in the registry, which is visible to enterprise ICAM. The registry generates Cerbos attribute schemas, so CI rejects any mission policy that uses an unregistered or misnamed attribute.
5. **The attribute is enterprise; its interpretation is local.** Holding a position is an enterprise fact. What that position may do in a given mission is mission policy.

Enterprise vocabulary and mission vocabulary

The enterprise owns the vocabulary: which enterprise attributes exist, their allowed values, and what each value means. The data steward applies that vocabulary to the mission's own data and is accountable for labeling accurately. Each layer interprets labels

for its own decisions, and the mission layer may only add conditions, never redefine or loosen an enterprise meaning.

Not every attribute a mission needs belongs in the enterprise vocabulary. One test decides where an attribute lives: **does it need to mean the same thing outside this mission, or must the enterprise decision point evaluate it?**

- **If yes**, it is enterprise vocabulary, defined and changed by enterprise ICAM. Classification and release markings are examples.
- **If no**, it is mission vocabulary, such as cell, case, mission role, project, task, or workflow stage. It is defined in the mission's own namespace, registered, and approved through mission governance, and it can never alias or shadow an enterprise term.

Three mechanisms keep the two vocabularies working together:

1. **Delegated sub-vocabularies.** Enterprise ICAM may define a parent attribute, such as mission compartment, and delegate management of its values to a mission, much as DNS delegates a subdomain. ICAM keeps the structure and the delegation; the mission manages the contents.
2. **Provisional attributes.** A mission may define a new attribute in its own namespace and use it immediately in restrictive rules. If the attribute proves to carry enterprise meaning, the mission nominates it for adoption into the enterprise vocabulary through the promotion path.
3. **Predictable vocabulary changes.** For changes that do require the enterprise vocabulary, co-design establishes an agreed request process and expected turnaround, so missions can plan around them.

The registry enforces these boundaries: enterprise attributes become fixed value lists in the Cerbos schemas, and mission attributes are validated against their namespace, so CI rejects any policy or label that uses an undefined value or crosses a namespace.

Responsibility matrix (RACI)

R: responsible for doing the work. A: accountable, exactly one per activity. C: consulted. I: informed.

Activity	Enterprise ICAM	Mission data steward policy shop	Mission engineering	Platform team	Engineering governance board	Product teams
Define marking vocabulary and taxonomy	A, R	C	I	I	C	I
Maintain subject attributes of record	A, R	I	I	I	I	I
Approve mission adoption of the pattern	A, R	R	I	C	C	I
Request and justify access envelopes	C	A, R	C	I	I	C
Approve access envelopes	A, R	C	I	I	C	I
Apply resource markings and mission tags	C	A	R	I	I	C
Define mission-derived attributes	C	A, R	C	I	C	I
Maintain the attribute registry	C	R	R	R	A	I
Author mission policy intent	I	A, R	C	I	I	C
Implement and test mission policies in Cerbos	I	A	R	C	I	I
Approve mission policy changes for release	C	R	C	I	A	I
Operate Tyk Gateway and Cerbos runtime	I	I	C	A, R	I	I
Change the composition rule	A	I	I	R	C	I
Exercise the kill switch	A	I	I	R	I	I

Activity	Enterprise ICAM	Mission data steward policy shop	Mission engineering	Platform team	Engineering governance board	Product teams
Integrate applications with the gateway	I	I	C	C	I	A, R
Review decision logs and audit	A	C	I	R	I	I

Two separations of duty are deliberate. The mission data steward policy shop authors mission policy, but release approval sits with the engineering governance board, so no single group both writes and approves a rule. The platform team operates the composition rule and kill switch, but only enterprise ICAM can authorize changing or using them, so the controls that could affect enterprise-level access are never self-governed. During the initial rollout phase, enterprise ICAM also approves every mission policy (see Rollout).

Cross-mission attribute sharing

Other missions may need our mission-derived attributes alongside their own and the enterprise's. When that happens, our mission becomes an attribute provider as well as a consumer. The governing principle is **share attributes, not policies**: other missions receive our facts and interpret them in their own policies, under the same narrow-only rule and the same enterprise ICAM oversight.

How attributes are exposed

- **A governed attribute service.** Consuming missions call a read API through Tyk Gateway, never our data stores or Cerbos policies directly. Callers authenticate with STS-exchanged service tokens, and the attribute service enforces its own authorization, because some attributes, such as cell membership, are sensitive in themselves.
- **Change events for consumers that cache.** Missions that need low latency subscribe to attribute change events, with the freshness expectation stated in the attribute registry.
- **Not through the enterprise token.** Mission attributes are not added to STS tokens unless enterprise ICAM formally adopts them, because an attribute in the enterprise token is effectively an enterprise attribute.

Attributes versus decisions

- When another mission needs **context for its own rules**, such as whether a user belongs to an active mission cell, we share the attribute.
- When the question is **about our resources or our mission**, such as whether a user may act on our mission's data, the other mission asks our decision point through AuthZEN rather than re-implementing our logic. Composition generalizes cleanly: the enterprise and every relevant mission must permit, and each mission can only narrow.

Governing rules

1. **The registry becomes a contract.** Every shared attribute carries a schema, a definition of meaning, an owner, a freshness expectation, and a versioning and deprecation policy, because other missions' policies depend on it.
2. **Consumers inherit the restrictive-only rule.** No mission may use another mission's attributes as a substitute for a clearance or access envelope.
3. **Sharing is approved, not assumed.** Each consuming mission is registered against the specific attributes it reads, so access to attributes is itself auditable by enterprise ICAM.
4. **Widely used attributes graduate.** When many missions depend on one of our attributes, that is the signal for enterprise ICAM to adopt it into the enterprise catalog, rather than letting a mission attribute quietly become enterprise-critical.

Responsibility additions

Activity	Enterprise ICAM	Providing mission's data steward policy shop	Consuming mission	Platform team	Engineering governance board
Define meaning and quality of a shared attribute	I	A, R	C	I	C
Approve a mission's access to shared attributes	C	A, R	R	I	I
Use shared attributes correctly in policy	I	C	A, R	I	I
Operate the attribute service and change events	I	C	I	A, R	I
Maintain the cross-mission attribute contract	C	R	C	I	A

Activity	Enterprise ICAM	Providing mission's data steward policy shop	Consuming mission	Platform team	Engineering governance board
Promote an attribute to the enterprise catalog	A, R	R	C	I	C

Anticipated objections and responses

Objection	Response
This creates a parallel IAM system.	The mission layer issues no identities, mints no tokens, and grants nothing. It refines access only within envelopes ICAM approves, under one sanctioned pattern ICAM governs.
The mission layer could grant access the enterprise denied.	The enterprise decision is evaluated first on every request. Deny-overrides is enforced in the gateway, not in mission policy, and automated tests on every policy change verify that no mission permit can override an enterprise deny. ICAM controls the composition rule.
We lose visibility.	ICAM gains visibility. Every decision logs both verdicts with a correlation ID, covering mission-level access that ICAM cannot see today.
Every mission will build its own.	Adoption is gated by ICAM approval, all missions use one pattern and one registry, and widely used attributes graduate to the enterprise catalog.
This bypasses our entitlement process.	New access still requires an ICAM-approved envelope through the existing process. Only refinements inside approved envelopes move to missions.

Objection	Response
This puts our ATO at risk.	The pattern maps to existing controls (below), runs in shadow mode before it enforces anything, and completes an independent security assessment before enforcement.
Mission teams lack the expertise to write access policy.	Policy intent comes from the data steward policy shop, implementation and tests from mission engineering, release approval from the governance board, and, during the initial phase, approval of every policy by ICAM.
Open-source components carry support and supply-chain risk.	Tyk Gateway (MPL 2.0) and Cerbos (Apache 2.0) are self-hosted, version-pinned, and scanned through our standard supply-chain controls, and commercial support options exist if required.

Control mapping

A preliminary mapping to NIST SP 800-53 Rev. 5, to be validated with the ISSO and authorizing official. Enhancement selection varies with each system's baseline and tailoring, so the specific enhancements listed here should be confirmed before they appear in any authorization package.

A major benefit of the pattern is control inheritance. Enterprise ICAM and the teams operating the gateway and mission decision point act as common control providers, so product teams inherit these controls rather than re-implementing and re-proving them in every system. The inheritance column uses three categories:

- **Common:** provided once by enterprise ICAM, the platform team, or the mission, and fully inherited by product systems.
- **Hybrid:** provided in part by the pattern, with a defined remaining responsibility for each product team.
- **System-specific:** owned entirely by the product team.

Control	How the pattern addresses it	Provider	Inheritance
AC-2 Account management	Enterprise accounts are unchanged; mission entitlements carry approval, expiry, and recertification	Enterprise ICAM; mission data steward policy shop	Hybrid
AC-3 Access enforcement	Tyk enforces the composed decision on every request; applications enforce in-app operations through the same decision layer	Platform team; product teams	Hybrid
AC-3(7) Role-based access control	Mission roles evaluated in mission policy	Mission	Common
AC-3(8) Revocation of access authorizations	Entitlement revocations take effect within the stated freshness window; the kill switch reverts a mission to enterprise-only decisions	Enterprise ICAM; mission	Common
AC-3(9) Controlled release	Release, print, and export decisions with obligations such as watermarking; applications honor the obligations	Mission; product teams	Hybrid
AC-3(10) Audited override of access control mechanisms	Break-glass access with justification, alerting, and review	Platform team; enterprise ICAM	Common
AC-3(13) Attribute-based access control	Decisions derived from governed subject, resource, and environment attributes	Enterprise ICAM; mission	Common

Control	How the pattern addresses it	Provider	Inheritance
AC-5 Separation of duties	Separations defined in the RACI; workflow separations such as author cannot approve enforced in policy; applications model the workflow states	Engineering governance board; mission; product teams	Hybrid
AC-6 Least privilege	Envelopes narrowed by mission policy; applications remain responsible for their own service accounts and administrative functions	Enterprise ICAM; mission; product teams	Hybrid
AC-6(7) Review of user privileges	Periodic recertification of mission entitlements	Mission data steward policy shop	Common
AC-6(9) Log use of privileged functions	Every decision, including privileged actions and overrides, logged with both verdicts	Platform team	Common
AC-16 Security and privacy attributes	Single authoritative source per attribute, governed registry, schema-enforced use; applications label objects at creation and propagate attributes	Enterprise ICAM; mission; product teams	Hybrid
AC-21 Information sharing	Governed cross-mission attribute sharing and decision delegation	Mission	Common

Control	How the pattern addresses it	Provider	Inheritance
AC-24 Access control decisions	Two standardized decision points with deny-overrides composition, enterprise first	Enterprise ICAM; mission; platform team	Common
AC-25 Reference monitor	The gateway is always invoked, isolated, and small enough to test; every authorization surface sits behind it; applications must not bypass it	Platform team; product teams	Hybrid
AU-2 and AU-12 Event logging and audit record generation	Both verdicts logged per request with a correlation ID	Platform team	Common
AU-3 Content of audit records	Records include subject, action, resource, attribute values used, both verdicts, and correlation ID	Platform team	Common
AU-6 Audit record review, analysis, and reporting	Enterprise ICAM reviews decision logs; mission reviews divergence and override reports	Enterprise ICAM; mission	Common
CA-7 Continuous monitoring	Decision logs and shadow-mode divergence reports provide ongoing evidence	Platform team; enterprise ICAM	Common
CM-3 Configuration change control	Mission policies change only through tested, reviewed, approved releases	Engineering governance board	Common

Control	How the pattern addresses it	Provider	Inheritance
CM-5 Access restrictions for change	Policy repository restricted to authorized authors, with approval required to release	Platform team; engineering governance board	Common
IA-2 Identification and authentication	Enterprise STS and MFA unchanged and remain the sole identity source	Enterprise ICAM	Common
IA-9 Service identification and authentication	Gateway service identity verified, for example through mTLS, and envelopes bound to the registered gateway	Platform team; enterprise ICAM	Common
IA-11 Re-authentication	Step-up authentication required by policy for sensitive actions and performed by the enterprise STS	Enterprise ICAM; mission	Common
SC-16 Transmission of security and privacy attributes	Attributes travel with requests and are carried on indexed objects; applications ensure their indexes include them	Platform team; product teams	Hybrid
SI-4 System monitoring	Decision logs, overrides, and divergence reports feed enterprise monitoring	Platform team; enterprise ICAM	Common

Access control responsibilities product teams retain

Control	Product team responsibility
AC-2 Account management	Any local or service accounts the application creates. The goal is none beyond service identities.

Control	Product team responsibility
AC-3 Access enforcement	Operations the gateway cannot see, such as internal service calls, background jobs, and GraphQL resolvers, must call the decision layer and apply generated filters, never local shortcuts.
AC-3(9) Controlled release	Honoring obligations returned with a decision, such as applying a watermark on print or export.
AC-6 Least privilege	Least privilege for the application's own service accounts, database credentials, and administrative functions.
AC-8 System use notification	System use banners where the application presents its own entry point.
AC-12 Session termination	The application's own session handling, including idle timeout and logout. Token lifetimes remain enterprise-controlled.
AC-14 Permitted actions without identification	Declaring any unauthenticated endpoints and their justification. The goal is none.
AC-16 Security and privacy attributes	Labeling objects correctly at creation and carrying attributes into indexes, caches, and derived data. The steward decides the label; the product implements it.
SC-16 Transmission of security and privacy attributes	Ensuring every index and data store the application maintains includes the attributes filters depend on.

Rollout

The rollout earns trust in stages, with enterprise ICAM holding the kill switch at every phase.

Phase	What happens	Enterprise ICAM role	Exit criteria
0. Co-design	ICAM and the mission jointly review the architecture, composition rule, attribute registry, and this document	Co-author and red team	ICAM concurrence on the design
1. Shadow mode	Tyk is in the request path enforcing the enterprise decision only; Cerbos evaluates every request and its would-be decisions are logged, not enforced	Reviews divergence reports	Every divergence reviewed and accepted by the mission and ICAM
2. Limited enforcement	One mission, one use case, mission decisions enforced	Approves every mission policy; holds the kill switch	Pilot measures met; independent security assessment complete
3. Steady state	Policy release approval moves to the governance board with ICAM sampling; additional missions adopt by ICAM decision	Samples policies; approves new missions and envelopes	Ongoing

The pilot measures, each compared to today's baseline: time to deliver a new rule inside an approved envelope, the volume of per-use-case entitlement requests reaching ICAM, end-to-end decision latency, and audit completeness, with zero tolerance for any decision where the mission layer permitted what the enterprise denied.

Why Tyk

- **Open source and self-hosted.** Tyk Gateway is released under MPL 2.0 and runs entirely inside our environment, which matters given our restrictions on external SaaS.

- **Native identity handling.** OIDC and JWT validation against the enterprise STS are built in, so no custom token code is needed.
- **AuthZEN-ready.** An AuthZEN plugin, maintained through the OpenID Foundation interop work, makes Tyk a standards-based enforcement point.
- **Extensible middleware chain.** Plugins in Go, Python, JavaScript, or any gRPC-capable language give us a supported path for composition and logging.
- **Declarative operations.** API definitions and policies can be managed as code through Tyk Operator, fitting our GitOps practices.

Cerbos pairs naturally: its decision point has implemented the AuthZEN 1.0 metadata and evaluation endpoints since v0.48, so Tyk calls it with no translation layer.

What does not change

- The enterprise STS and MFA remain the sole source of identity.
- The enterprise decision service remains authoritative and is consulted first on every request.
- Attributes of record, clearances, envelopes, and their approval processes remain with enterprise ICAM.

What gets better

- Mission rules ship at the mission's pace through reviewed, tested policy changes, inside boundaries ICAM sets.
- The bespoke auth proxy is retired in favor of a supported, standards-based gateway.
- Enterprise ICAM sees more, approves the boundaries that matter, and fields fewer narrow requests.
- Applications are decoupled from any specific decision engine, preserving future choice.

Risks and mitigations

Risk	Mitigation
Mission policy widens access by mistake	Deny-overrides enforced in the gateway; enterprise evaluated first; mission policies tested in CI; composition rule controlled by ICAM
Added latency from two decisions	Enterprise checked first with short-circuit on deny; Cerbos deployed close to the gateway; batch evaluation for permission-heavy interfaces
Gateway becomes a single point of failure	Highly available Tyk replicas; fail closed on decision point errors
Plugin maintenance burden	Plugins built in CI against each gateway version as part of the upgrade pipeline
Business logic creeping into the gateway	Gateway code limited to validate, ask, compose, and log; changes reviewed against that boundary
Stale claims in long sessions	Short-lived tokens; enterprise decision point authoritative for revocation; Shared Signals and CAEP if enterprise ICAM supports them

Decisions requested

1. Endorse the layered authorization pattern as an extension of enterprise ICAM governance, including the narrow-only composition principle.
2. Charter a phased pilot in one mission, co-led by enterprise ICAM and the mission, using Tyk Gateway and Cerbos.
3. Designate an enterprise ICAM co-lead with approval authority over the composition rule, envelopes, and phase gates.

Open questions for co-design

- Does the enterprise decision service expose an AuthZEN interface? If not, a thin adapter plugin in Tyk translates to its native API.
- Can the Tyk AuthZEN plugin target two decision points in sequence, or do we chain two plugin instances or write a small Go composition plugin?

- Which claims does the STS token carry today, including assurance level and methods, and which must the mission layer receive?
- Where do decision logs land, and what retention does the enterprise audit function require?
- Does enterprise ICAM support Shared Signals and CAEP for near-real-time revocation?

Sources

- [NIST SP 800-207: Zero Trust Architecture](#)
- [NIST SP 800-162: Guide to Attribute Based Access Control](#)
- [NIST SP 800-53 Rev. 5: Security and Privacy Controls](#)
- [OpenID Foundation: Authorization API 1.0 Final Specification approved](#)
- [Tyk Gateway repository and license](#)
- [Tyk: AuthZEN for API gateways](#)
- [Cerbos PDP v0.48 AuthZEN support](#)

Appendix: Glossary

Term	Definition
ABAC (attribute-based access control)	An access model in which decisions are made by evaluating attributes of the subject, the resource, the action, and the environment against policy, rather than by assigning fixed permissions to individuals.
Access envelope	A stable, coarse entitlement approved by enterprise ICAM that defines the outer boundary of what a population may do within a mission, such as cleared attorneys accessing that mission's case files. Mission policy refines access inside the envelope and can never exceed it.

Term	Definition
Attribute	A fact used in an access decision: about a person (clearance, position, case assignment), a resource (classification marking, case ID), or the environment (network zone, authentication strength).
Attribute of record	An attribute whose authoritative source is an enterprise system, such as identity, clearance, or formal position assignment. Owned by enterprise ICAM or personnel, and never written or cached by the mission layer.
Attribute registry	The governed catalog of every attribute: its owner, system of record, allowed values, freshness expectation, and which decision points may use it. It generates the schemas that CI uses to validate policies.
Authentication strength	How strongly a user proved their identity and when, carried in the token as assurance level and authentication methods (often the acr and amr claims). Used by policy to decide whether step-up is needed.
AuthZEN	The OpenID Foundation Authorization API 1.0, a standard interface for enforcement points to request decisions from decision points. It lets applications and gateways work with any compliant decision engine.
CAEP and Shared Signals	OpenID Foundation standards for sharing security events, such as a revoked session or a change in user risk, between systems in near real time.
Cerbos	The open-source decision engine (Apache 2.0) used as the mission decision point. Policies are written as code, tested in CI, and evaluated without storing state.

Term	Definition
Composition rule	The rule the gateway uses to combine the enterprise and mission decisions. In this design it is deny-overrides: access is permitted only if both permit. Changes require enterprise ICAM approval.
Confused deputy	A flaw in which a service with legitimate access is tricked into using it on behalf of a caller who lacks that access. Token exchange and policies that check both the user and the calling service close this gap.
Correlation ID	A unique identifier attached to each request so that both decision verdicts, the enforcement action, and downstream activity can be traced together in audit logs.
Data steward policy shop	The mission team accountable for applying markings and tags to mission data, defining mission attributes, and authoring the intent of mission policies.
Delegated sub-vocabulary	An arrangement in which enterprise ICAM defines a parent attribute and delegates management of its values to a mission, similar to how DNS delegates a subdomain.
Deny-overrides	A composition rule in which any deny wins. Used here so the mission layer can only restrict what the enterprise permits.
Entitlement	A recorded approval that gives a person or population a specific attribute or right. Enterprise entitlements are managed by ICAM; mission entitlements, such as case assignments, are managed by the mission.
Enterprise vocabulary	The enterprise-defined set of attributes and allowed values with enterprise-wide meaning, such as classification and release markings. Missions apply it but cannot redefine it.

Term	Definition
ICAM (identity, credential, and access management)	The enterprise function and systems responsible for identity, authentication, credentials, and enterprise access decisions.
JWT and OIDC	JSON Web Token, the signed token format the STS issues, and OpenID Connect, the authentication protocol built on it. Tyk validates both natively.
Kill switch	The enterprise ICAM control that reverts a mission to enterprise-only decisions at any time, restoring today's baseline.
MFA (multi-factor authentication)	Authentication that requires more than one type of proof, such as a smart card plus a PIN.
Mission layer	The mission-owned portion of the architecture, consisting of the mission decision point, mission policies, and mission attributes. Sometimes called the edge.
Mission vocabulary	Attributes defined in a mission's own namespace that have meaning only within that mission, such as cell, case, or workflow stage.
Mission-derived attribute	An attribute owned and maintained by a mission, such as case assignment or mission role. Usable only to restrict access.
Narrow-only	The core principle that the mission layer may add restrictions to enterprise decisions but can never grant access the enterprise has denied.
PAP (policy administration point)	Where policies are written, reviewed, and managed. Here, mission policies are managed as code in a reviewed repository.

Term	Definition
PDP (policy decision point)	The component that evaluates policy and returns a decision. This design has two: the enterprise decision point and the Cerbos mission decision point.
PEP (policy enforcement point)	The component that intercepts a request, asks for a decision, and enforces the result. In this design, Tyk Gateway.
PIP (policy information point)	A source a decision point queries for attributes it does not receive in the request, such as an enterprise lookup of clearances or the mission attribute service.
Provisional attribute	A new attribute defined in a mission's namespace and used immediately in restrictive rules, which may later be nominated for adoption into the enterprise vocabulary.
RACI	A responsibility matrix: Responsible (does the work), Accountable (owns the outcome, one per activity), Consulted, and Informed.
Shadow mode	A rollout phase in which the mission decision point evaluates every request and logs what it would decide, without enforcing anything, so its behavior can be reviewed before it affects access.
Step-up authentication	Requiring a signed-in user to authenticate again, more strongly, before a sensitive action. Mission policy decides when it is needed; the enterprise STS is the only component that performs it.
STS (security token service)	The enterprise service that issues signed tokens after a user authenticates, and that exchanges tokens for downstream services.

Term	Definition
System of record	The single authoritative source for an attribute. If two systems can write the same attribute, neither is authoritative.
Token exchange (RFC 8693)	A standard way for a service to trade a user's token for a new token scoped to a downstream service, preserving both the user and the calling service.
Tyk Gateway	The open-source API gateway (MPL 2.0) used as the enforcement point. It validates tokens, requests decisions through AuthZEN, composes them, and logs both verdicts.
Zero Trust	A security model in which no request is trusted by default and every access is decided per request based on identity, policy, and context, as described in NIST SP 800-207.